

Veritabanı Güvenliği ve Erişim Kontrolü Projesi

<https://drive.google.com/file/d/1jsMWccLsBut2wHNZUvevXxdWdwNpCIPJ/view?usp=sharing>

Bu projede SQL Server üzerinde veritabanı güvenliği uygulamaları gerçekleştirilmiştir. Gerçek bir banka müşteri veri seti kullanılarak kullanıcı erişim yönetimi, rol bazlı yetkilendirme, veri şifreleme, SQL injection saldırılarına karşı koruma, audit log sistemi ve Transparent Data Encryption (TDE) uygulamaları yapılmıştır.

Kullanılan Veri Seti: Projede Kaggle platformundan alınmış gerçek bir banka müşteri veri seti kullanılmıştır. Veri seti toplam 10127 müşteri kaydı içermektedir.

1. Veritabanı ve Tabloların Oluşturulması

İlk aşamada BankSecurityDB isimli veritabanı oluşturulmuştur. CSV dosyasından gelen ham verilerin tutulması için Customers_Staging tablosu oluşturulmuştur. Daha sonra güvenlik projesinde kullanılacak temiz veriler için Customers tablosu oluşturulmuştur. CSV dosyasındaki veriler BULK INSERT komutu kullanılarak staging tabloya aktarılmıştır. Ardından gerekli kolonlar seçilerek ana müşteri tablosuna taşınmıştır.

2. Veri Kontrol İşlemleri

Veri aktarımından sonra kayıt sayıları kontrol edilmiştir. Customers_Staging ve Customers tablolarında toplam 10127 kayıt bulunduğu görülmüştür. Bu durum veri aktarımının eksiksiz şekilde gerçekleştirildiğini göstermektedir.

StagingRecordCount											
1	10127										
CleanRecordCount											
1	10127										
	CustomerRowID	CLIENTNUM	Attrition_Flag	Customer_Age	Gender	Dependent_count	Education_Level	Marital_Status	Income_Category	Card_Category	Months_on_book
1	1	768805383	"Existing Custom...	45	"M"	3	"High School"	"Married"	"\$60K - \$80K"	"Blue"	39
2	2	818770008	"Existing Custom...	49	"F"	5	"Graduate"	"Single"	"Less than \$40...	"Blue"	44
3	3	713982108	"Existing Custom...	51	"M"	3	"Graduate"	"Married"	"\$80K - \$120K"	"Blue"	36
4	4	769911858	"Existing Custom...	40	"F"	4	"High School"	"Unknown"	"Less than \$40...	"Blue"	34
5	5	709106358	"Existing Custom...	40	"M"	3	"Uneducated"	"Married"	"\$60K - \$80K"	"Blue"	21
6	6	713061558	"Existing Custom...	44	"M"	2	"Graduate"	"Married"	"\$40K - \$60K"	"Blue"	36
7	7	810347208	"Existing Custom...	51	"M"	4	"Unknown"	"Married"	"\$120K +"	"Gold"	46
8	8	818906208	"Existing Custom...	32	"M"	0	"High School"	"Unknown"	"\$60K - \$80K"	"Silver"	27
9	9	710930508	"Existing Custom...	37	"M"	3	"Uneducated"	"Single"	"\$60K - \$80K"	"Blue"	36
	Card_Category	CustomerCount									
1	"Blue"	9436									
2	"Silver"	555									
3	"Gold"	116									
4	"Platinum"	20									
	Attrition_Flag	CustomerCount									
1	"Existing Customer"	8500									
2	"Attrited Customer"	1627									

3. Hassas Veri Yönetimi ve Hash İşlemleri

Hassas müşteri bilgilerinin tutulması için CustomerSensitiveInfo isimli ayrı bir tablo oluşturulmuştur. Bu tabloda e-posta bilgisi, telefon numarası, kart numarası ve şifre bilgisi bulunmaktadır. Şifre alanında güvenlik amacıyla düz metin yerine SHA2_256 algoritması ile hash işlemi uygulanmıştır.

Sonuçlar

İletiler

	SensitiveInfoID	CustomerRowID	CLIENTNUM	Email	Phone	CardNumber	PasswordHash
1		1	768805383	customer1@bank.com	05558805383	4532-9876-5383-0000	4B2357ED0DDE1B84B4325C21E7A88BBA6C77C60C08AB995B4...
2	2	2	818770008	customer2@bank.com	05558770008	4532-9876-0008-0000	D9AECDF6F448C92874B5708BDBC6C97D90F072A0D0E4C70419...
3	3	3	713982108	customer3@bank.com	05553982108	4532-9876-2108-0000	3A219A774B1E46A2309BD0D0D7DA39F4D25079C53FFC63EF4...
4	4	4	769911858	customer4@bank.com	05559911858	4532-9876-1858-0000	F188F265386D4D1CD1EBA24CF7F2DB3503A2F4E496F5362644...
5	5	5	709106358	customer5@bank.com	05559106358	4532-9876-6358-0000	CB5352822469B9517E645022093374ECF7A392237F6A6B4E33...
6	6	6	713061558	customer6@bank.com	05553061558	4532-9876-1558-0000	600C910F0531DEB28A8FDFCEC50DB1C7AC0BA81011DF132...
7	7	7	810347208	customer7@bank.com	05550347208	4532-9876-7208-0000	CB504D818C47421FB283B2BD1BA96AC4C67E1D8E721E54736...
8	8	8	818906208	customer8@bank.com	05558906208	4532-9876-6208-0000	E3D0C4EB82FE5F4F71F0C67F3BECC2CD09586FC959C5ED69D...
9	9	9	710930508	customer9@bank.com	05550930508	4532-9876-0508-0000	D950EE4C5D5E7BB0FE0F259AEC9E8AC080055F9372AB1634C...
10	10	10	719661558	customer10@bank.com	05559661558	4532-9876-1558-0000	FF25569C66F253F7CB69ADB83A4F6CEFF7E0C03D9FC3A57985...

4. Kullanıcı Roller ve Yetkilendirme

Projede rol bazlı erişim kontrolü uygulanmıştır. AdminRole, BankEmployeeRole ve AuditorRole rolü oluşturulmuştur. Daha sonra SQL Server Authentication yöntemi ile SecurityOfficerUser, BankEmployeeUser ve AuditorUser kullanıcıları oluşturulmuştur.

AdminRole: Tüm tablolarda SELECT, INSERT, UPDATE ve DELETE işlemleri yapabilir.

BankEmployeeRole: Customers tablosunda SELECT ve UPDATE yapabilir, DELETE işlemi yapamaz ve hassas müşteri bilgilerine erişemez.

AuditorRole: Sadece SELECT işlemi yapabilir, INSERT, UPDATE ve DELETE işlemleri yapamaz ve hassas müşteri bilgilerine erişemez.

Bu yapı sayesinde kullanıcıların yalnızca yetkili oldukları işlemleri gerçekleştirmesi sağlanmıştır.

	WindowsAuthenticationLogin	CurrentDatabaseUser
1	DESKTOP-980S7Q2\SEDEF	dbo

	UserName	RoleName
1	SecurityOfficerUser	AdminRole
2	AuditorUser	AuditorRole
3	BankEmployeeUser	BankEmployeeRole
4	dbo	db_owner

	RoleName	permission_name	state_desc	TableName
1	AdminRole	DELETE	GRANT	Customers
2	AdminRole	INSERT	GRANT	Customers
3	AdminRole	SELECT	GRANT	Customers
4	AdminRole	UPDATE	GRANT	Customers
5	AdminRole	DELETE	GRANT	CustomerSensitiveInfo
6	AdminRole	INSERT	GRANT	CustomerSensitiveInfo
7	AdminRole	SELECT	GRANT	CustomerSensitiveInfo
8	AdminRole	UPDATE	GRANT	CustomerSensitiveInfo
9	AuditorRo...	DELETE	DENY	Customers
10	AuditorRo...	INSERT	DENY	Customers
11	AuditorRo...	SELECT	GRANT	Customers
12	AuditorRo...	UPDATE	DENY	Customers
13	AuditorRo...	SELECT	DENY	CustomerSensitiveInfo
14	BankEmp...	DELETE	DENY	Customers
15	BankEmp...	SELECT	GRANT	Customers
16	BankEmp...	UPDATE	GRANT	Customers
17	BankEmp...	SELECT	DENY	CustomerSensitiveInfo

5. Yetki Testleri

Yetkilendirme sisteminin doğru çalışıp çalışmadığı test edilmiştir. BankEmployeeUser kullanıcısı müşteri verilerini görüntüleyebilmiş, veri güncelleme işlemi yapabilmiş ancak veri silme işlemi yapamamıştır. Ayrıca CustomerSensitiveInfo tablosuna erişmeye çalışıldığında SQL Server tarafından erişim reddedilmiştir. AuditorUser kullanıcısı ise yalnızca veri okuma işlemi gerçekleştirebilmiş, güncelleme işlemi yapamamıştır.

```
{5 satır etkilendi}

{1 satır etkilendi}
İleti 229, Düzey 14, Durum 5, Satır 19
The DELETE permission was denied on the object 'Customers', database 'BankSecurityDB', schema 'dbo'.
İleti 229, Düzey 14, Durum 5, Satır 23
The SELECT permission was denied on the object 'CustomerSensitiveInfo', database 'BankSecurityDB', schema 'dbo'.

{5 satır etkilendi}
İleti 229, Düzey 14, Durum 5, Satır 38
The UPDATE permission was denied on the object 'Customers', database 'BankSecurityDB', schema 'dbo'.

Tamamlanma süresi:2026-05-28T11:27:03.2633904+03:00
```

6. SQL Injection Güvenlik Testleri

Projede SQL injection saldırılarına karşı güvenlik testi gerçekleştirilmiştir. İlk olarak aşağıdaki mantıkta güvensiz bir sorgu örneği gösterilmiştir:

WHERE CLIENTNUM = 768805383 OR 1 = 1

Bu durumda OR 1=1 koşulu her zaman doğru olduğu için birden fazla kayıt dönebilmektedir. Bu durum SQL injection saldırılarında görülen temel güvenlik açıklarından biridir. Daha sonra güvenli sorgu yapısı için parametrelili stored procedure oluşturulmuştur. GetCustomerByClientNum isimli stored procedure sayesinde kullanıcı girdisi doğrudan SQL sorgusuna dahil edilmemiştir.

	CustomerRowID	CLIENTNUM	Attrition_Flag	Customer_Age	Gender	Dependent_count	Education_Level	Marital_Status	Income_Category	Card_Category	Months_on_book	Total_Relationship_Count
72...	7295	708870408	"Existing Customer"	53	"M"	4	"Unknown"	"Single"	"Less than \$40K"	"Blue"	43	6
72...	7296	795844983	"Existing Customer"	45	"F"	3	"High School"	"Married"	"\$40K - \$60K"	"Blue"	39	6
72...	7297	828294933	"Attrited Customer"	49	"F"	3	"High School"	"Married"	"Less than \$40K"	"Blue"	45	3
72...	7298	713531808	"Existing Customer"	38	"F"	1	"Doctorate"	"Married"	"Less than \$40K"	"Blue"	28	6
72...	7299	712307283	"Attrited Customer"	54	"M"	1	"College"	"Single"	"\$120K +"	"Blue"	37	6
73...	7300	715778358	"Existing Customer"	45	"M"	5	"Graduate"	"Married"	"\$120K +"	"Blue"	26	6
73...	7301	778910883	"Attrited Customer"	53	"M"	2	"Unknown"	"Married"	"\$80K - \$120K"	"Blue"	34	4
73...	7302	710637183	"Existing Customer"	48	"F"	4	"Graduate"	"Single"	"Unknown"	"Blue"	40	3
73...	7303	712781883	"Existing Customer"	36	"F"	1	"Uneducated"	"Married"	"Less than \$40K"	"Blue"	36	6
73...	7304	709664658	"Existing Customer"	40	"M"	4	"Unknown"	"Unknown"	"\$80K - \$120K"	"Blue"	27	4
73...	7305	717574683	"Existing Customer"	53	"F"	3	"Unknown"	"Married"	"\$40K - \$60K"	"Blue"	46	6
73	7306	771497283	"Existing Customer"	40	"F"	2	"High School"	"Divorced"	"Less than \$40K"	"Blue"	28	4
4												
	CustomerRowID	CLIENTNUM	Attrition_Flag	Customer_Age	Gender	Income_Category	Card_Category					
1	1	768805383	"Existing Customer"	46	"M"	"\$60K - \$80K"	"Blue"					

7. Windows Authentication ve SQL Server Audit

Projede Windows Authentication bağlantısı kontrol edilmiştir. SYSTEM_USER çıktısı mevcut Windows kullanıcısının SQL Server'a başarılı şekilde bağlandığını göstermiştir. Daha sonra SQL Server Audit özelliği kullanılarak kullanıcı aktivitelerinin izlenmesi sağlanmıştır.

Customers tablosu üzerindeki SELECT, UPDATE ve DELETE işlemleri audit sistemi tarafından kayıt altına alınacak şekilde yapılandırılmıştır. Bu sayede kullanıcı aktivitelerinin izlenebilirliği sağlanmıştır.

	WindowsAuthenticationLogin	CurrentDatabaseUser
1	DESKTOP-980S7Q2\SEDEF	dbo

	name	is_state_enabled
1	BankSecurityDatabaseAudit	1

8. Transparent Data Encryption (TDE)

Son aşamada SQL Server'ın Transparent Data Encryption (TDE) özelliği kullanılmıştır. Öncelikle Master Key, Certificate ve Database Encryption Key oluşturulmuştur. Daha sonra BankSecurityDB veritabanı için şifreleme aktif edilmiştir. Şifreleme işlemlerinde AES_256 algoritması kullanılmıştır. Bu yöntem sayesinde veritabanı dosyaları disk seviyesinde şifrelenerek korunmaktadır.

	DatabaseName	encryption_state	key_algorithm	key_length
1	tempdb	3	AES	256
2	BankSecurityDB	2	AES	256